MODULE 23 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Compliance, Data Residency and Sovereignty

Keep data where the law says, choose the right sovereignty model, keep audit trails for AI, collect evidence, and model threats before they arrive.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 23 of 52

admin@sthithapragna.com

Residency or sovereignty?

DATA RESIDENCY

Where data is stored and processed

- Choice of Region
- Deny other Regions by policy
- Control replication and copies
- Watch cross-Region features

DIGITAL SOVEREIGNTY

Who controls and operates it

- Who can access the data
- Who operates the infrastructure
- Which laws and entities apply
- Control of keys and metadata

THE TIEBREAKER

Residency is solved with Regions and policy. Sovereignty may need a different operating model.

Enforcing Region choices

- **SCP deny** on aws:RequestedRegion outside the approved list.
- **Exempt global services** such as IAM, Organizations, CloudFront and Route 53.
- **Control Tower Region deny** control packages the same idea.
- **Opt-in Regions** stay disabled unless enabled; default Regions cannot be disabled.
- **Exempt a break-glass role** by principal ARN where needed.

> ON THE EXAM
>
> Default Regions cannot be switched off. Residency is enforced with a deny guardrail, not by disabling Regions.

Where data can quietly cross a border

FEATURE	RESIDENCY CONTROL
S3 replication	Deny replication rules to other Regions
AWS Backup copies	Restrict copy destinations by policy
Bedrock cross-Region inference	Geographic profile only; deny global profiles
Global tables, Aurora Global Database	Add replicas only in approved Regions
CloudFront	Edge caches worldwide; use geo restriction or avoid

ON THE EXAM

A Region deny stops resources. It does not stop features that copy or process data elsewhere.

Bedrock inference and residency

- **Geographic profiles** (US, EU, APAC, JP) route only within that geography.
- **Global profiles** may route to any supported commercial Region.
- **Stored data stays in the source Region**: logs, knowledge bases, configuration.
- **CloudTrail** logs in the source Region, showing the inference Region used.
- **One Region only?** Invoke the model directly there, without a profile.

> ON THE EXAM
>
> Deny global profiles with an SCP on bedrock:InferenceProfileArn; allow your geography's prefix.

Sovereignty options on AWS

OPTION	WHAT IT ADDS
Standard Region plus controls	Residency, Nitro isolation, your keys, even external
Dedicated Local Zones	Infrastructure for one customer, at a chosen location
Outposts	AWS infrastructure in your own facility
AWS European Sovereign Cloud	Separate partition, EU-resident operations, EU entities

ON THE EXAM

Operated only by EU residents, independent of other Regions: the European Sovereign Cloud.

Audit trails for regulated and AI workloads

- **Who did what:** organisation CloudTrail, including Bedrock and AgentCore calls.
- **What was said:** Bedrock model invocation logging to S3.
- **What was blocked:** the guardrail trace, returned in the logged response.
- **Tamper-proof retention:** S3 Object Lock in compliance mode.
- **Separate account:** the log archive, outside workload administrators' reach.

> ON THE EXAM
>
> A regulated AI audit trail needs the call, the content, and the guardrail outcome, all locked.

Whose evidence is it?

AWS'S CONTROLS

AWS Artifact

- SOC, ISO, PCI and other reports
- Evidence that AWS meets its share
- Agreements such as a HIPAA BAA
- Downloaded, on demand, self-service

YOUR CONTROLS

Your evidence pipeline

- Config compliance history
- Security Hub CSPM standard scores
- CloudTrail and invocation logs
- Reports from aggregated data

THE TIEBREAKER

An auditor asking for AWS's certifications or a BAA: AWS Artifact. Proof of your controls: your own data.

Threat modelling a design

01
Model
Draw components, data flows and trust boundaries

02
Identify
Ask what can go wrong, for example with STRIDE

03
Mitigate
Map each threat to a control or accept it

04
Validate
Test mitigations; record decisions

05
Revisit
Repeat when the design changes

ON THE EXAM

Threat modelling happens during design, and again on every significant change.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
Only these Regions, global services still work	SCP Region deny with exemptions
AI requests must stay in the EU	EU geographic profile, deny global
EU-resident operators, separate from global AWS	European Sovereign Cloud
Auditor wants AWS's reports or a BAA	AWS Artifact
Prove who prompted what, tamper-proof	CloudTrail, invocation logs, Object Lock
Find design risks before launch	Threat model during design

ON THE EXAM

Separate location from control, and AWS's evidence from yours.

> A regulator requires that Meridian Freight's EU subsidiary creates resources only in eu-central-1 and eu-west-1.
>
> Administrators must still be able to use IAM, Route 53 and CloudFront, and the rule must apply to every account in the subsidiary's OU.

What should the solutions architect implement?

A Disable all other Regions in each account settings page

B An IAM policy on every role denying other Regions

C An SCP on the OU denying requests where aws:RequestedRegion is not one of the two, exempting global services

D An AWS Config rule that reports resources in other Regions

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **Disable Regions**
Only opt-in Regions can be disabled; default ones cannot.

B **IAM policy per role**
Administrators can edit or bypass it.

C **SCP Region deny**
Every principal in the OU, with global services still working.

D **Config rule**
Reports after creation; does not prevent it.

THE SIGNAL

Residency across an OU, preventive, global services intact: SCP with exemptions.

Meridian Freight's EU customer-service assistant uses Amazon Bedrock in eu-central-1 and needs more throughput than one Region provides at peak.

Customer prompts must never be processed outside the EU, and developers must not be able to switch to a profile that could route elsewhere.

What should the solutions architect implement?

A. A global cross-Region inference profile for maximum throughput

B. Direct invocation in eu-central-1 only

C. Provisioned throughput in a US Region

D. The EU geographic inference profile, with an SCP denying global inference profile ARNs

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Global profile

Can route to any supported Region, including outside the EU.

B Direct, one Region

Keeps data in the EU, but does not add the throughput needed.

C US provisioned throughput

Processes EU prompts in the US.

D EU profile plus SCP

More capacity across EU Regions, and global profiles blocked.

THE SIGNAL

More throughput, EU only, enforced: geographic profile plus a deny on global profiles.

> A German public-sector customer requires that Meridian Freight's workload runs on infrastructure operated and supported only by EU residents, managed by EU legal entities, and independent of AWS's other Regions.
>
> Customer-created metadata, such as IAM roles and tags, must also stay in the EU.

What should the solutions architect recommend?

A Deploy the workload in the AWS European Sovereign Cloud

B Use eu-central-1 with an external key store

C Use eu-central-1 with an SCP Region deny

D Use AWS Outposts in a German colocation facility

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A European Sovereign Cloud

Separate partition, EU-resident operations, EU entities, EU metadata.

B Region plus XKS

Controls keys, not who operates the infrastructure.

C Region deny

Residency only; operations are not EU-only or independent.

D Outposts

Location of hardware, still managed from its parent Region.

THE SIGNAL

Operators, legal entities and independence are sovereignty words: European Sovereign Cloud.

> Meridian Freight is launching a health-logistics service that handles protected health information in the US. The compliance team must sign a business associate addendum with AWS.
>
> External auditors also want AWS's current SOC 2 and ISO 27001 reports.

Where should the compliance team obtain these?

A. A Config conformance pack for HIPAA

B. AWS Artifact, for both the agreement and the reports

C. Security Hub CSPM, with the relevant standard enabled

D. A support case requesting the documents

◆ PAUSE AND DECIDE

Where should the compliance team obtain these?

A Conformance pack

Checks Meridian's resources; it is not AWS's paperwork.

B AWS Artifact

Self-service agreements and AWS compliance reports.

C CSPM

Scores Meridian's configuration, not AWS's controls.

D Support case

Unnecessary; Artifact is self-service.

THE SIGNAL

AWS's reports and agreements with AWS: Artifact. Proof of your configuration: Config and CSPM.

> A financial regulator requires Meridian Freight's credit-decision assistant to keep, for ten years, a record of who invoked the model, the full prompt and response, and whether a guardrail blocked or masked content.
>
> Records must be impossible to alter or delete, even by administrators.

What should the solutions architect implement?

A. CloudWatch Logs in the workload account with ten-year retention

B. An organisation CloudTrail trail only

C. Application logs written to DynamoDB with point-in-time recovery

D. CloudTrail plus model invocation logging, including guardrail results, delivered to the log archive account in S3 with Object Lock in compliance mode

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **CloudWatch Logs locally**

Workload administrators can delete the log group.

B **CloudTrail only**

Records who, but not the prompt, response or guardrail result.

C **DynamoDB logs**

Mutable by administrators, and depends on application code.

D **Trail, invocation logs, Object Lock**

Who, what and the guardrail outcome, in immutable storage.

THE SIGNAL

Who, what, and what was blocked, kept immutably outside the workload account.

> Meridian Freight is designing a partner portal that will accept uploaded customs documents and pass them to an AI extraction agent.
>
> The security architect wants to identify risks such as spoofed partners, tampered documents and prompt injection, and agree mitigations before any code is written.

What should the solutions architect do?

A. Commission a penetration test after launch

B. Enable GuardDuty and Security Hub in the portal account

C. Run a threat model during design, using STRIDE across the data flows and trust boundaries, and record a mitigation for each threat

D. Apply the AWS Foundational Security Best Practices standard

◆ PAUSE AND DECIDE

What should the solutions architect do?

A Penetration test after launch

Valuable later, but the requirement is before code exists.

B GuardDuty and Security Hub

Detect problems in running systems, not design risks.

C Threat model during design

Structured identification of threats with agreed mitigations, before building.

D Best practices standard

Generic configuration checks, nothing about this design.

THE SIGNAL

Design-time risk, specific to this architecture: a threat model.

What to carry out of this module

- **Residency is location; sovereignty is control** of access and operations.
- **SCP Region deny** with global service exemptions; watch features that copy data.
- **Bedrock:** geographic profiles for residency; deny global profiles.
- **Artifact** for AWS's evidence; your logs and Config for yours.
- **AI audit trail**: who, what, and guardrail outcome, locked in the log archive.

> ON THE EXAM
>
> Separate location from control, and AWS's evidence from yours. Threat model during design.